

BAOBAB LOYALTY

Programme de fidelisation WhatsApp pour hotels en Afrique francophone

SECURITE ET CONFORMITE DES DONNEES CLIENTS

Document Technique et Juridique

Destinataires :	Equipe informatique · Equipe juridique · Hoteliers
Version :	2.0 — Avril 2026
Classification :	Confidentiel — Usage interne et partenaires
Conformite :	RGPD · Loi 2013-450 (CI) · Loi 2008-12 (SN) · Loi 09-08 (MA)

Ce document integre : securite technique, obligations de conformite, DPA, notice clients, registre des traitements

TABLE DES MATIERES

1. **Presentation de l'application**
 2. **Donnees collectees sur les clients des hotels**
 3. **Ou sont hebergees les donnees**
 4. **Comment les donnees sont securisees (4 niveaux)**
 - 4.1 Niveau 1 — Authentification JWT
 - 4.2 Niveau 2 — Isolation par RLS PostgreSQL
 - 4.3 Niveau 3 — Separation des cles d'accès
 - 4.4 Niveau 4 — Secrets dans coffre-fort
 5. **Flux complet d'une donnee client**
 6. **Qui peut acceder aux donnees**
 7. **Donnees transmises a des tiers**
 8. **Mesures de securite — Recapitulatif**
 9. **Points d'attention juridique**
 - 9.4 Transferts internationaux — Conformite par pays
 10. **Obligations de conformite par pays**
 - 10.2 Declaration ARTCI (Cote d'Ivoire)
 - 10.3 Declaration CDP (Senegal)
 - 10.4 En cas de violation de donnees
 11. **Contrat de Sous-traitance (DPA) — Resume**
 - 11.1 Engagements de Baobab Loyalty
 - 11.2 Engagements de l'hotelier
 - 11.3 Sous-traitants ulterieurs autorises
 - 11.4 Fin de contrat et sort des donnees
 12. **Notice d'information clients — Template**
 13. **Registre des activites de traitement — Synthese**
 14. **Checklist de conformite complete**
 15. **Exemple de migration SQL — Securite table clients**
-

1. Presentation de l'application

Baobab Loyalty est un logiciel SaaS (Software as a Service) destine aux proprietaires d'hotels en Afrique francophone. Il leur permet de :

- Importer leur base de clients depuis un fichier CSV
- Segmenter automatiquement ces clients selon leur date de derniere visite (3, 6, 9 mois d'inactivite)
- Envoyer des campagnes de fidelisation par WhatsApp avec des offres personnalisees
- Suivre les reservations generees et les revenus en FCFA depuis un tableau de bord

Chaque hotelier possede un espace totalement isole. Il ne voit et ne peut interagir qu'avec ses propres donnees. L'isolation est garantie au niveau de la base de donnees (RLS PostgreSQL).

2. Donnees collectees sur les clients des hotels

Champ	Nature	Obligatoire	Exemple
`nom`	Nom du client	Oui	"Aminata Diallo"
`email`	Adresse email	Non	"aminata@gmail.com"
`telephone`	Numero de telephone	Non	" +221 77 000 00 00"
`whatsapp`	Numero WhatsApp	Non	" +221 77 000 00 00"
`derniere_visite`	Date du dernier sejour	Oui	"2025-10-15"
`notes`	Notes internes hotelier	Non	"Client VIP, chambre 204"

Ces donnees sont fournies par l'hotelier lui-meme (via import CSV). Baobab Loyalty n'est pas a l'origine de la collecte initiale — c'est l'hotelier qui les a recueillies lors des sejours.

3. Ou sont hebergees les donnees

3.1 Infrastructure

Les donnees sont hebergees sur Supabase (PostgreSQL cloud), dans la region EU West (Europe de l'Ouest — Irlande) par default, soumise au RGPD europeen.

Point juridique important : L'hotelier doit verifier avec l'equipe Baobab Loyalty la region de stockage pour s'assurer de la conformite avec les lois locales (RGPD, Loi 09-08 Maroc, PPDP Senegal, Loi n 2013-450 du 19 juin 2013 relative a la protection des donnees a caractere personnel en Cote d'Ivoire).

3.2 Tables de la base de donnees

Table	Role
clients	Les voyageurs (nom, email, telephone, date de visite)
campaigns	Historique des campagnes WhatsApp envoyees

sent_messages

Journal des messages (quel message, a quel client, quand)

redemptions

Suivi des clics sur les offres reçues par WhatsApp

reservations

Reservations generees suite aux campagnes

profiles

Compte de l'hotelier (nom hotel, email, abonnement)

4. Comment les donnees sont securisees — 4 niveaux

4.1 Niveau 1 — Authentification par jeton JWT

Chaque hotelier se connecte avec un email et un mot de passe. Supabase genere un jeton JWT (JSON Web Token) signe cryptographiquement, valide pour une duree limitee. Aucune operation sur les donnees n'est possible sans ce jeton valide.

```
// supabase/functions/_shared/auth.ts
export async function requireAuth(req: Request): Promise<AuthResult> {
  const authHeader = req.headers.get("Authorization");
  if (!authHeader || !authHeader.startsWith("Bearer ")) {
    return { user: null, error: "Authorization header manquant ou invalide" };
  }
  const token = authHeader.replace("Bearer ", "");
  const { data: { user }, error } = await supabase.auth.getUser(token);
  if (error || !user) {
    return { user: null, error: "Jeton invalide" };
  }
  return { user, userClient, error: null };
}
```

4.2 Niveau 2 — Isolation totale par RLS (Row Level Security)

C'est le mecanisme de securite le plus important. Le RLS PostgreSQL garantit qu'un hotelier ne peut JAMAIS acceder aux clients d'un autre hotelier. La regle `auth.uid() = profile_id` est verifiee systematiquement au niveau du moteur de base de donnees, independamment du code.

```
ALTER TABLE public.clients ENABLE ROW LEVEL SECURITY;

CREATE POLICY "Users can view own clients"
  ON public.clients FOR SELECT
  USING (auth.uid() = profile_id);

CREATE POLICY "Users can insert own clients"
  ON public.clients FOR INSERT
  WITH CHECK (auth.uid() = profile_id);

CREATE POLICY "Users can update own clients"
  ON public.clients FOR UPDATE
  USING (auth.uid() = profile_id);

CREATE POLICY "Users can delete own clients"
  ON public.clients FOR DELETE
  USING (auth.uid() = profile_id);
```

Ce que cela signifie juridiquement : Meme en cas de bug dans le code applicatif, la base de donnees elle-meme refusera toute

requete tentant d'accéder aux données d'un autre hotelier.

4.3 Niveau 3 — Separation des cles d'accès

Cle	Qui l'utilise	Ce qu'elle permet
Anon Key (publique)	L'application web	Accès limite, soumis au RLS
JWT utilisateur	L'hotelier connecte	Accès a ses données uniquement (RLS actif)
Service Role Key (secrete)	Fonctions backend uniquement	Accès total — JAMAIS exposee au navigateur

4.4 Niveau 4 — Secrets dans coffre-fort

Aucun secret (cle API, mot de passe) n'est écrit en dur dans le code source. Tous sont stockés dans Supabase Vault (coffre-fort chiffre) ou variables d'environnement.

```
Secrets dans Supabase Vault :
STRIPE_SECRET_KEY      -> Cle de paiement Stripe
RESEND_API_KEY         -> Cle d'envoi d'emails
OPENROUTER_API_KEY     -> Cle IA (generation de messages)
MONEROO_API_KEY        -> Cle de paiement FCFA
MONEROO_WEBHOOK_SECRET -> Cle de verification webhook
```

5. Flux complet d'une donnee client

1. L'hotelier importe un fichier CSV depuis son logiciel hotelier
2. Le fichier est traite dans le navigateur (parsing CSV cote client)
3. Les donnees sont envoyees par lot (100 lignes) vers Supabase via l'API securisee (JWT + RLS)
4. Les donnees sont stockees dans la table `clients` avec `profile_id` = identifiant de l'hotelier
5. L'hotelier selectionne un segment (ex : clients inactifs 6 mois) — filtre par `profile_id`
6. L'hotelier choisit une offre et lance la campagne — enregistrement dans `campaigns` + `sent\_messages`
7. Les messages WhatsApp sont envoyes aux clients concernes — chaque envoi est journalise
8. Si un client clique sur le lien et reserve — enregistrement dans `redemptions` et `reservations`

6. Qui peut acceder aux donnees des clients des hotels

Acteur	Acces	Niveau d'accès
L'hotelier propriétaire	Oui	Ses clients uniquement (RLS)
Un autre hotelier	Non	Bloque par RLS au niveau base de donnees
Equipe Baobab Loyalty (admin)	Oui, limite	Via Supabase Dashboard, maintenance uniquement
Services tiers (Stripe, Resend)	Non	Ne recoivent jamais les donnees clients
Systemes IA (OpenRouter)	Non	Seul le texte du message genere est traite, pas les PII

7. Donnees transmises a des tiers

Service tiers	Donnees transmises	Finalite
Supabase (PostgreSQL)	Toutes les donnees	Hebergement et base de donnees
Vercel	Aucune donnee client	Hebergement de l'application web uniquement
Resend	Email de l'hotelier uniquement	Envoi d'emails transactionnels a l'hotelier
Stripe / Moneroo	Donnees de facturation hotelier	Paieement de l'abonnement
OpenRouter / IA	Texte du message (sans PII)	Generation de texte marketing
WhatsApp Business API	Numero de telephone du client	Envoi du message de campagne

Les donnees des clients des hotels (nom, email, telephone) ne sont JAMAIS transmises a Stripe, Resend, ou OpenRouter. Seul WhatsApp recoit le numero de telephone.

8. Mesures de securite — Recapitulatif

Mesure	Implementee	Detail
Authentification JWT	Oui	Supabase Auth, sessions securisees
Isolation des donnees (RLS)	Oui	4 politiques sur la table clients
Chiffrement en transit	Oui	HTTPS/TLS 1.3 sur toutes les connexions
Secrets dans coffre-fort	Oui	Supabase Vault + variables d'environnement
Verification signature webhook	Oui	HMAC-SHA256 pour webhooks de paiement
Journalisation des actions	Oui	Table sent_messages pour tracabilite
Chiffrement au repos	Partiel	PostgreSQL chiffre, pas de chiffrement colonne par colonne
Limitation du debit	Partiel	Gere par Supabase et Vercel
Controle d'accès admin	Oui	Colonne role = 'admin' dans profiles

9. Points d'attention juridique

9.1 Base legale du traitement

L'hotelier est responsable de traitement au sens du RGPD et des lois africaines applicables. Baobab Loyalty agit en tant que sous-traitant. Un contrat de sous-traitance (DPA) doit être signé entre l'hotelier et Baobab Loyalty (voir Section 11).

9.2 Duree de conservation

Type de donnee	Duree	Motif
Donnees clients (nom, contact, visite)	Duree du compte actif	Necessite fonctionnelle
Journaux de messages envoyes	3 ans apres l'envoi	Tracabilite legale
Donnees de reservation	5 ans	Obligation comptable
Donnees apres cloture	Suppression sous 30 jours	Contrat de sous-traitance

9.3 Droits des personnes concernees

Les clients des hotels (voyageurs) peuvent exercer leurs droits (accès, rectification, suppression) auprès de l'hotelier. L'hotelier dispose des outils dans Baobab Loyalty pour supprimer un client spécifique de sa base.

9.4 Transferts internationaux — Conformite par pays

Pays	Loi applicable	Autorite de controle	Statut transfert AWS EU West
Union Europeenne	RGPD — Reglement (UE) 2016/679	CNIL	Conforme — RGPD applique directement
Senegal	Loi n 2008-12 du 25 janv. 2008	CDP — www.cdp.sn	Conforme sous reserve declaration CDP
Maroc	Loi n 09-08 du 18 fevr. 2009	CNDP — www.cndp.ma	Conforme — accord partiel UE/Maroc
Cote d'Ivoire	Loi n 2013-450 du 19 juin 2013	ARTCI — www.artci.ci	Conforme — declaration ARTCI requise
Cameroun	Loi n 2010/021	—	Conforme — meme logique que CI

Point critique Cote d'Ivoire : Le niveau de protection RGPD est superieur a la Loi n 2013-450, mais le transfert de donnees hors de CI doit faire l'objet d'une declaration prealable a l'ARTCI (Articles 8 a 14). Cette obligation est a la charge de l'hotelier. Un formulaire pre-rempli est disponible (Document 04 — Declaration ARTCI).

10. Obligations de conformite par pays — Ce que doit faire l'hotelier

10.1 Recapitulatif des actions obligatoires

Action	Cote d'Ivoire	Senegal	Maroc	UE/France	Delai
Signer le DPA	Oui	Oui	Oui	Oui	Avant utilisation
Notice info clients	Oui	Oui	Oui	Oui	Avant import
Declaration ARTCI	Oui	—	—	—	Avant utilisation
Declaration CDP	—	Oui	—	—	Avant utilisation
Declaration CNDP	—	—	Oui	—	Avant utilisation
Registre traitements	Recommande	Recommande	Recommande	Obligatoire	Avant import
Formation personnel	Oui	Oui	Oui	Oui	Sous 60 jours

10.2 Declaration ARTCI — Cote d'Ivoire

Base legale : Loi n 2013-450 du 19 juin 2013. Declaration requise AVANT utilisation de Baobab Loyalty.

Champ du formulaire ARTCI	Ce que l'hotelier indique
Finalite du traitement	Fidelisation clientele hoteliere par communications WhatsApp
Categories de donnees	Nom, email, telephone, date de derniere visite
Destinataires	Baobab Loyalty (sous-traitant), WhatsApp Business API
Duree de conservation	Duree de l'abonnement actif Baobab Loyalty
Transferts hors CI	Oui — vers serveurs AWS EU West (Irlande) — proteges par RGPD
Mesures de securite	Chiffrement TLS, JWT, RLS PostgreSQL

Delai de reponse ARTCI : 1 mois (sans reponse = declaration acceptee). Gratuit.

Adresse : Tour Postel 2001, Avenue Marchand, Abidjan-Plateau — www.artci.ci

10.3 Declaration CDP — Senegal

1. Creer un compte sur www.cdp.sn
2. Remplir le formulaire de declaration en ligne
3. Joindre le DPA signe avec Baobab Loyalty
4. Conserver le recepisse

Sanction en cas de non-declaration : jusqu'a 5 millions de FCFA d'amende (CDP).

10.4 En cas de violation de donnees (incident de securite)

Etape	Action
1	L'hotelier contacte Baobab Loyalty : support@baobabloyalty.com
2	Baobab Loyalty notifie l'hotelier dans les 72h avec rapport d'incident

L'hotelier notifie l'autorite competente de son pays

Si risque grave pour les personnes : les informer directement

Autorite	Pays	Delai legal	Contact
ARTCI	Cote d'Ivoire	Des que possible	www.artci.ci
CDP	Senegal	Des que possible	cdp@cdp.sn
CNDP	Maroc	Des que possible	www.cndp.ma
CNIL	France / UE	72 heures	www.cnil.fr

11. Contrat de Sous-traitance (DPA) — Resume

Le DPA est obligatoire dans TOUS les pays avant d'utiliser Baobab Loyalty. A signer et envoyer a : support@baobabloyalty.com

11.1 Engagements de Baobab Loyalty (sous-traitant)

Obligation	Detail
Traitement sur instruction	Ne traite les donnees que sur instruction documentee de l'hotelier
Confidentialite	Tout acces couvert par une obligation de confidentialite
Securite technique	Chiffrement TLS 1.3, AES-256, JWT, RLS PostgreSQL, Supabase Vault
Notification violations	Notification de l'hotelier dans les 72 heures apres detection
Suppression fin contrat	Toutes les donnees supprimees dans les 30 jours apres resiliation
Droits des personnes	Assistance a l'hotelier pour repondre aux exercices de droits
Audit	Fourniture des informations necessaires a l'audit (preavis 30 jours)

11.2 Engagements de l'hotelier (responsable de traitement)

Obligation	Detail
Liceite du traitement	Disposer d'une base legale valable (interet legitime, consentement)
Information des clients	Informer les voyageurs du traitement et de la transmission a Baobab Loyalty
Declarations reglementaires	Effectuer les declarations ARTCI / CDP / CNDP selon son pays
Qualite des donnees	S'assurer de l'exactitude des donnees importees

11.3 Sous-traitants ulterieurs autorises

Sous-traitant	Pays	Role	Donnees transmises
Supabase Inc.	USA (AWS EU West)	Hebergement base de donnees	Toutes les donnees
Vercel Inc.	USA	Hebergement web	Aucune donnee client
Resend Inc.	USA	Emails transactionnels	Email hotelier uniquement
OpenRouter	USA	Generation IA	Texte message (sans PII)
WhatsApp (Meta)	USA	Envoi messages	Numero de telephone
Moneroo	Afrique	Paiements FCFA	Donnees facturation hotelier

11.4 Fin de contrat et sort des donnees

1. L'hotelier peut exporter ses donnees pendant 30 jours apres resiliation
2. Apres 30 jours : suppression definitive et irreversible de tous les serveurs
3. Un certificat de suppression est fourni sur demande dans les 15 jours

12. Notice d'information clients — Template

L'hôtelier est légalement tenu d'informer ses clients (voyageurs) que leurs données sont utilisées dans Baobab Loyalty. Ce texte est à personnaliser et afficher à la réception (ou via au moins 2 canaux parmi ceux listés ci-dessous).

12.1 Version Cote d'Ivoire — Loi n 2013-450 du 19 juin 2013

Champ	Contenu à afficher
Responsable du traitement	[Nom de l'hôtel], [adresse], représenté par [nom du dirigeant]
Finalité	Fidelisation clientèle hôtelière par communications WhatsApp personnalisées
Données traitées	Nom, téléphone/WhatsApp, email, date de dernière visite
Sous-traitant	Baobab Loyalty (contrat de sous-traitance signé)
Transfert hors CI	Oui — serveurs AWS EU West (Irlande) — protégés par RGPD. N déclaration ARTCI : [...]
Droits	Accès, rectification, opposition (Articles 22 à 29 Loi 2013-450) — contact : [email hôtel]
Reclamations	ARTCI — Tour Postel 2001, Avenue Marchand, Abidjan-Plateau — www.artci.ci

12.2 Moyens de diffusion (choisir au moins 2)

- Affichage à la réception (format A4 encadré)
- Inclus dans le formulaire de check-in signé par le client
- Envoi par email à la confirmation de réservation
- Publication sur le site web de l'hôtel (page Confidentialité)

13. Registre des activités de traitement — Synthèse

13.1 Traitements en tant que sous-traitant (pour les hôteliers)

Ref.	Traitement	Données	Hebergement
ST-01	Gestion base clients hôtelière	Nom, email, tel, WhatsApp, date visite	AWS EU West
ST-02	Envoi campagnes WhatsApp	Numéro tel, texte message	WhatsApp Business API
ST-03	Tracking réservations et offres	ID client, statut clic, montant resa	AWS EU West

13.2 Traitements en tant que responsable de traitement (données hôteliers abonnés)

Ref.	Traitement	Base légale	Durée conservation
RT-01	Gestion des comptes hôteliers	Exécution du contrat	Durée abonnement + 3 ans
RT-02	Facturation et paiements	Contrat + obligation légale	7 ans (obligation comptable)
RT-03	Emails transactionnels	Exécution du contrat	Logs 1 an
RT-04	Génération contenu IA	Intérêt légitime (aucune PII transmise à l'IA)	Non applicable

14. Checklist de conformite complete

14.1 Pour l'hotelier — Actions a effectuer

- [] Signer le DPA avec Baobab Loyalty et l'envoyer a support@baobabloyalty.com
- [] Afficher la Notice d'information clients a la reception (ou 1 autre canal)
- [] Si Cote d'Ivoire : deposer le formulaire de declaration a l'ARTCI (Document 04)
- [] Si Senegal : declarer le traitement sur www.cdp.sn
- [] Si Maroc : declarer ou demander autorisation a la CNDP (www.cndp.ma)
- [] Si site web : ajouter un paragraphe Baobab Loyalty dans la politique de confidentialite
- [] Former le personnel qui accede a Baobab Loyalty (ne jamais partager ses identifiants)
- [] Mettre en place un processus de reponse aux droits des clients (delai 30 jours)

14.2 Pour Baobab Loyalty — Engagements en place

- [x] DPA disponible et signable (Document 01)
- [x] Hebergement EU West (Irlande) conforme RGPD
- [x] RLS PostgreSQL — isolation totale des donnees par hotelier
- [x] JWT authentication + chiffrement TLS 1.3
- [x] Secrets dans Supabase Vault (aucun secret en clair dans le code)
- [x] Procedure de notification violation sous 72h
- [x] Suppression des donnees a la resiliation sous 30 jours
- [x] Sous-traitants ulterieurs conformes RGPD avec CCT
- [x] Registre des activites de traitement maintenu (Document 05)

15. Exemple de migration SQL — Securite de la table clients

Le fichier suivant, versionne dans le code source sous supabase/migrations/005_clients_and_config.sql, montre l'implementation complete de la securite sur la table clients :

```
-- Creation de la table
CREATE TABLE IF NOT EXISTS public.clients (
  id                UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  profile_id        UUID REFERENCES public.profiles(id) ON DELETE CASCADE NOT NULL,
  nom               TEXT NOT NULL,
  email             TEXT,
  telephone         TEXT,
  derniere_visite   DATE NOT NULL,
  notes             TEXT,
  created_at        TIMESTAMPTZ DEFAULT NOW(),
  updated_at        TIMESTAMPTZ DEFAULT NOW()
);

-- Index de performance
CREATE INDEX IF NOT EXISTS idx_clients_profile
  ON public.clients(profile_id);

-- ACTIVATION DU ROW LEVEL SECURITY
ALTER TABLE public.clients ENABLE ROW LEVEL SECURITY;

CREATE POLICY "Users can view own clients"
  ON public.clients FOR SELECT USING (auth.uid() = profile_id);

CREATE POLICY "Users can insert own clients"
  ON public.clients FOR INSERT WITH CHECK (auth.uid() = profile_id);

CREATE POLICY "Users can update own clients"
  ON public.clients FOR UPDATE USING (auth.uid() = profile_id);

CREATE POLICY "Users can delete own clients"
  ON public.clients FOR DELETE USING (auth.uid() = profile_id);

-- Acces service role pour fonctions backend securisees
CREATE POLICY "Service role can manage clients"
  ON public.clients FOR ALL USING (auth.role() = 'service_role');
```

Ce fichier est archive dans le depot Git de l'application, versionne et auditable a tout moment par l'hotelier, l'equipe juridique ou une autorite de controle.

Document genere le 27 avril 2026 — Baobab Loyalty — Version 2.0

Ce document est confidentiel et destine aux equipes techniques, juridiques et aux partenaires hoteliers.